

**FATEC BARUERI – PADRE DANILO JOSÉ DE OLIVEIRA OHL CURSO DE GESTÃO
DA TECNOLOGIA DA INFORMAÇÃO**

**DESENVOLVIMENTO E IMPLEMENTAÇÃO DE UM GATEWAY DE
PAGAMENTO PARA A PAVPLAS**

**RAFAEL THIENGO REIS GUSTAVO SIRQUEIRA SOARES DA SILVA STANLEY
SOUSA DO VALE CAUÃ AZEREDO GOLDEN RODRIGUES NAYARA TEIXEIRA DA
SILVA HEITOR SOARES TANAN BRUNO TEMOTEO DE MACEDO**

BARUERI – SP 2026

**RAFAEL THIENGO REIS GUSTAVO SIRQUEIRA SOARES DA SILVA STANLEY
SOUSA DO VALE CAUÃ AZEREDO GOLDEN RODRIGUES NAYARA TEIXEIRA DA
SILVA HEITOR SOARES TANAN BRUNO TEMOTEO DE MACEDO**

**DESENVOLVIMENTO E IMPLEMENTAÇÃO DE UM GATEWAY DE
PAGAMENTO PARA A PAVPLAS**

Monografia apresentada ao curso de Gestão da
Tecnologia da Informação da FATEC Barueri –
Padre Danilo José de Oliveira Ohl, como requi-
sito para avaliação acadêmica, contemplando a
análise, a modelagem, o desenvolvimento e a
validação de uma proposta de gateway de paga-
mento para a empresa PavPlas.
Orientador: Prof. Vander Ribeiro Elme

BARUERI – SP 2026

RESUMO

Este trabalho analisa o processo de vendas e pagamentos da empresa PavPlas e propõe a modelagem de um gateway de pagamento integrado ao comércio eletrônico, ao estoque, ao financeiro, à logística e ao sistema de gestão empresarial. No cenário atual, o site funciona como catálogo e a conclusão das vendas depende de interações realizadas por WhatsApp, consulta manual de estoque, negociação de frete, envio de dados bancários e conferência de comprovantes. Esse fluxo fragmentado gera retrabalho, dependência de horário comercial, riscos de falha na conciliação e dificuldade de rastreamento.

A proposta de solução organiza a jornada de compra em um fluxo digital composto por catálogo, carrinho, validação de estoque, cálculo de frete, checkout e processamento de pagamentos por PIX, boleto bancário e cartão de crédito. Também são especificadas regras para atualização automática do pedido, emissão fiscal, geração de ordem de separação e conciliação financeira. A partir do documento de requisitos, foram incorporados perfis de usuário, controle de acesso baseado em papéis, histórias de usuário, critérios de aceitação, mascaramento de dados sensíveis e logs de auditoria. O resultado é uma base de requisitos e arquitetura capaz de orientar o desenvolvimento futuro, com foco em automação, segurança, rastreabilidade e conformidade com a Lei Geral de Proteção de Dados.

Palavras-chave: gateway de pagamento. Gestão de processos. Integração de sistemas. Automação de vendas. Controle de acesso. LGPD.

ABSTRACT

This study analyzes the sales and payment process of PavPlas and proposes the modeling of an integrated payment gateway connected to e-commerce, inventory, finance, logistics, and enterprise management systems. In the current scenario, the website works as a product catalog and sales completion depends on WhatsApp interactions, manual inventory checks, freight negotiation, bank-detail sharing, and receipt verification. This fragmented workflow generates rework, dependence on business hours, reconciliation risks, and limited traceability.

The proposed solution organizes the purchasing journey into a digital flow composed of catalog, shopping cart, inventory validation, freight calculation, checkout, and payment processing through PIX, bank slip, and credit card. Rules are also specified for automatic order updates, invoicing, separation-order generation, and financial reconciliation. Based on the requirements document, user profiles, role-based access control, user stories, acceptance criteria, sensitive-data masking, and audit logs were incorporated. The result is a requirements and architecture baseline to guide future development, focusing on automation, security, traceability, and compliance with the Brazilian General Data Protection Law.

Keywords: payment gateway. Process management. Systems integration. Sales automation. Access control. LGPD.

SUMÁRIO

1	INTRODUÇÃO	1
1.1	Contextualização	1
1.2	Problema de Pesquisa	1
1.3	Justificativa	2
1.4	Objetivo Geral	2
1.5	Objetivos Específicos.....	2
2	REFERENCIAL TEÓRICO	3
2.1	Sistemas de Pagamento.....	3
2.2	Gateway de Pagamento.....	3
2.3	APIs REST.....	4
2.4	Integração de Sistemas.....	4
2.5	Segurança da Informação.....	4
2.6	Banco de Dados	5
2.7	Engenharia de Software	5
2.8	LGPD	6
3	METODOLOGIA	6
3.1	Tipo de Pesquisa	6
3.2	Levantamento de Requisitos.....	6
3.3	Metodologia de Desenvolvimento	7
4	ANÁLISE DO PROBLEMA.....	7
4.1	Processo Atual (As-Is)	7
4.2	Revisão do Processo As-Is.....	8
4.3	Problemas Identificados.....	9
4.4	Processo Proposto (To-Be)	9
4.5	Requisitos Funcionais	10
4.5.1	Tabela de Requisitos Funcionais.....	10

4.5.2	Regras de Negócio Associadas	11
4.6	Perfis de Usuário e Jornadas	11
4.7	Histórias de Usuário e Critérios de Aceitação	12
4.7.1	RU01 – Autenticação Segura com Controle por Papéis (RBAC).....	12
4.7.2	RU02 – Gestão de Estornos e Operações Sensíveis do Gateway	12
4.7.3	RU03 – Visibilidade Restrita de Pedidos para Logística	12
4.7.4	RU04 – Mascaramento de Dados Sensíveis e Conformidade	12
4.7.5	RU05 – Logs de Auditoria de Acesso e Alteração	13
4.8	Requisitos Administrativos (Backoffice)	13
4.9	Requisitos Não Funcionais	14
5	MODELAGEM E ARQUITETURA	14
5.1	Arquitetura da Solução	14
5.2	Casos de Uso.....	15
5.3	Modelo de Dados	15
5.4	Fluxo de Pagamento.....	16
6	SEGURANÇA	16
6.1	Autenticação e Autorização	16
6.2	Proteção de Dados	17
6.3	Criptografia	17
6.4	Controle de Acesso	17
6.5	LGPD e Auditoria	18
7	CONCLUSÃO	18
7.1	Considerações Finais	18
7.2	Limitações.....	19
7.3	Trabalhos Futuros	19

1 INTRODUÇÃO

A transformação digital modificou a forma como empresas realizam vendas, atendem clientes e controlam suas operações. Em ambientes competitivos, a presença digital precisa ser acompanhada por processos integrados, capazes de reduzir atividades manuais, registrar decisões e oferecer respostas rápidas ao consumidor. A gestão de processos de negócio contribui para visualizar o fluxo ponta a ponta, identificar gargalos e alinhar tecnologia, pessoas e regras organizacionais [1].

A PavPlas comercializa peças para máquinas industriais e, no cenário analisado, utiliza o site principalmente como vitrine. A efetivação da venda ocorre por meio de conversas no WhatsApp, consultas manuais de estoque e frete, negociação de valores e confirmação de pagamentos por PIX ou transferência bancária. Esse modelo atende às necessidades básicas do negócio, mas limita a escalabilidade e aumenta a dependência de atividades executadas por diferentes setores.

1.1 Contextualização

O processo atual envolve atendimento comercial, consulta de disponibilidade, definição de preço e frete, envio de instruções de pagamento, conferência financeira, separação do produto, emissão fiscal e expedição. Como as informações não percorrem um fluxo único, o pedido pode ser digitado mais de uma vez, o comprovante pode ser analisado manualmente e a liberação logística depende da comunicação entre pessoas.

O modelo proposto transforma o site institucional em uma plataforma de comércio eletrônico integrada a um gateway de pagamento. A compra passa a ser estruturada por catálogo, carrinho, checkout, processamento da transação e atualização do pedido. Em seguida, os setores financeiro, fiscal e logístico recebem informações consistentes e rastreáveis.

1.2 Problema de Pesquisa

O problema de pesquisa consiste em compreender como a integração de um gateway de pagamento ao processo de vendas da PavPlas pode centralizar transações, reduzir atividades manuais, aumentar a segurança e melhorar a comunicação entre vendas, estoque, financeiro e logística. A questão orientadora é: **como modelar uma solução de gateway de pagamento que**

automatize o ciclo de compra sem comprometer o controle de acesso, a rastreabilidade e a proteção de dados pessoais?

1.3 Justificativa

O projeto é relevante para a PavPlas porque enfrenta problemas concretos de operação, tais como retrabalho, demora na confirmação de pagamentos, risco de divergência entre estoque e catálogo e dificuldade de acompanhamento do pedido. A automação pode reduzir a quantidade de tarefas repetitivas e estabelecer regras claras para que somente pedidos pagos avancem para a separação.

Do ponto de vista técnico, o estudo articula APIs, banco de dados, integração de sistemas, autenticação, autorização, logs e segurança de transações. Do ponto de vista acadêmico, permite aplicar conhecimentos de análise de processos, engenharia de software e modelagem de requisitos em um caso organizacional real, sem confundir a proposta de arquitetura com uma implantação já concluída.

1.4 Objetivo Geral

Analisar, modelar e propor o desenvolvimento de um gateway de pagamento integrado ao processo de vendas da PavPlas, visando automatizar e centralizar as etapas de compra e pagamento, reduzir atividades manuais e retrabalho, aumentar a segurança das transações e melhorar a integração entre vendas, estoque, financeiro e logística.

1.5 Objetivos Específicos

1. levantar e analisar o processo atual de vendas e pagamentos da PavPlas, identificando suas principais etapas, gargalos e limitações;
2. mapear os requisitos funcionais, administrativos e não funcionais necessários para a solução proposta;
3. documentar perfis de usuário, jornadas, histórias de usuário e critérios de aceitação;
4. modelar o fluxo de vendas e pagamentos no cenário futuro, considerando a automação das principais atividades;
5. projetar a integração do gateway com vendas, estoque, financeiro, logística e ERP;
6. especificar pagamentos por PIX, boleto bancário e cartão de crédito;

7. definir atualização automática do status dos pedidos após o processamento das transações;
8. aplicar medidas de segurança para proteção de informações e transações;
9. estabelecer critérios de teste e validação para a implementação futura.

2 REFERENCIAL TEÓRICO

Este capítulo apresenta os conceitos que sustentam a proposta. A discussão combina gestão de processos, gateways de pagamento, interfaces de integração, segurança, persistência de dados, engenharia de software e proteção de dados pessoais. Os conceitos são utilizados como referência para interpretar o processo da PavPlas e organizar os requisitos do sistema.

2.1 Sistemas de Pagamento

Sistemas de pagamento são conjuntos de instituições, regras, tecnologias e procedimentos utilizados para autorizar, registrar e liquidar transações. Em uma operação de comércio eletrônico, o sistema precisa conectar a intenção de compra do cliente, os dados do pedido, a forma de pagamento escolhida e o retorno de aprovação, recusa ou pendência. A qualidade desse fluxo depende da consistência das informações e da capacidade de comunicar o resultado às áreas que executarão as etapas seguintes.

No contexto da PavPlas, os meios previstos são PIX, boleto bancário e cartão de crédito. Cada modalidade possui um ciclo de processamento próprio, mas todas precisam produzir um resultado padronizado para o pedido. Essa padronização permite que o estoque, o faturamento e a logística trabalhem com estados conhecidos, como “Pendente”, “Pago”, “Em separação”, “Enviado”, “Concluído” e “Cancelado”.

2.2 Gateway de Pagamento

Um gateway de pagamento atua como intermediário entre a aplicação de vendas e os participantes do ecossistema financeiro. Ele recebe uma solicitação, encaminha os dados de forma protegida ao processador ou provedor, acompanha o resultado e devolve ao sistema uma resposta que pode ser associada ao pedido. A função do gateway não se limita à autorização: ele também pode apoiar notificações, conciliação, registro de eventos e tratamento de falhas [3].

Na solução proposta, o gateway deve ser isolado por uma camada de integração. Essa camada evita que regras específicas de um provedor contaminem o núcleo do comércio eletrô-

nico e permite substituir ou adicionar provedores no futuro. O pedido somente deve avançar para a expedição depois que o sistema receber uma confirmação confiável e registrar o evento correspondente.

2.3 APIs REST

APIs REST organizam a comunicação entre sistemas por meio de recursos identificados por URLs e operações realizadas com métodos HTTP. Em uma implementação compatível com a proposta, recursos como pedidos, pagamentos, usuários, produtos e entregas podem ser expostos por endpoints. O método GET consulta, POST cria ou solicita processamento, PUT ou PATCH atualiza e DELETE remove quando a regra de negócio permitir.

As mensagens devem adotar uma representação consistente, preferencialmente JSON, com códigos de resposta adequados, validação de entrada, autenticação e registro de erros. O HTTP define semânticas compartilhadas para métodos, códigos de status e conteúdo das mensagens; por isso, essas decisões devem ser documentadas na especificação da API [4]. Também é recomendável utilizar idempotência nas operações de pagamento, de modo que uma repetição de requisição não produza cobrança duplicada.

2.4 Integração de Sistemas

A integração de sistemas permite que aplicações distintas troquem dados e eventos com significado comum. No projeto, o comércio eletrônico deve comunicar-se com o gateway, o estoque, o ERP, o serviço de frete, o serviço de notificações e os módulos administrativos. A integração precisa definir contratos, responsáveis, periodicidade, tratamento de erros e mecanismos de reconciliação.

A arquitetura deve considerar tanto respostas síncronas quanto eventos assíncronos. O checkout pode aguardar a criação de uma cobrança, enquanto a confirmação definitiva de um boleto ou de um cartão pode chegar por webhook. Para evitar inconsistências, cada evento deve possuir identificador, data, origem, status e relação com o pedido, permitindo reprocessamento controlado e investigação posterior.

2.5 Segurança da Informação

A segurança da informação deve preservar confidencialidade, integridade, disponibilidade, autenticidade e rastreabilidade. Em um gateway, isso inclui autenticação de usuários e serviços,

autorização por perfil, proteção de credenciais, criptografia em trânsito, validação de mensagens, controle de sessão, registro de auditoria e monitoramento de falhas.

O documento de requisitos determina que usuários não autorizados sejam bloqueados, que a sessão expire após 30 minutos de inatividade e que operações sensíveis, como estornos acima de um limite, exijam dupla confirmação. Essas regras convertem princípios de segurança em comportamentos verificáveis do sistema. A referência OWASP ASVS pode apoiar a definição de controles de segurança para aplicações web e serviços [6].

2.6 Banco de Dados

O banco de dados deve persistir entidades necessárias ao funcionamento e à rastreabilidade da solução. Entre elas estão usuário, perfil, permissão, cliente, produto, estoque, pedido, item do pedido, pagamento, evento do gateway, endereço, entrega, nota fiscal e log de auditoria. Relacionamentos e restrições devem impedir registros órfãos e preservar a consistência das transações.

O histórico de status merece tratamento próprio. Em vez de sobrescrever todas as alterações, o sistema deve registrar a transição, o horário, o agente responsável e a justificativa quando aplicável. A separação entre dados operacionais e trilhas de auditoria facilita consultas, relatórios e análises de incidentes.

2.7 Engenharia de Software

Engenharia de software compreende atividades de requisitos, análise, projeto, implementação, testes, implantação e manutenção. Para este trabalho, a engenharia de requisitos é especialmente importante porque traduz necessidades de diferentes setores em comportamentos observáveis, prioridades e critérios de aceite [7].

A modelagem proposta adota uma abordagem iterativa, na qual os requisitos são refinados por ciclos. Cada ciclo deve produzir incrementos verificáveis, como catálogo e carrinho, checkout, integração de pagamento, atualização de pedidos e controles administrativos. Testes funcionais, de integração, segurança e recuperação de falhas devem acompanhar a evolução da solução.

2.8 LGPD

A Lei nº 13.709/2018 dispõe sobre o tratamento de dados pessoais, inclusive em meios digitais, e tem como objetivo proteger direitos fundamentais de liberdade e privacidade [5]. No gateway, podem ser tratados dados de identificação, contato, endereço, histórico de pedidos e informações relacionadas ao pagamento. A solução deve aplicar finalidade, necessidade, segurança, prevenção, transparência e responsabilização, limitando o acesso ao mínimo necessário.

A proposta não prevê o armazenamento de dados completos de cartão em texto puro. O sistema deve trabalhar com tokenização ou encaminhamento seguro ao provedor, mantendo apenas informações minimizadas, como bandeira e últimos quatro dígitos, quando necessárias para atendimento. O tratamento deve ser documentado e submetido à avaliação da instituição responsável pelo projeto antes da implantação.

3 METODOLOGIA

A pesquisa é aplicada, de abordagem qualitativa e caráter descritivo, pois busca compreender um processo organizacional específico e produzir uma proposta tecnológica para um problema prático. O objeto de análise é o fluxo de vendas e pagamentos da PavPlas, considerando as atividades atuais, os participantes, os sistemas envolvidos e as regras necessárias ao cenário futuro.

3.1 Tipo de Pesquisa

A pesquisa aplicada é adequada porque o resultado esperado não é apenas uma discussão conceitual, mas uma base de requisitos e arquitetura que possa orientar o desenvolvimento de um gateway integrado. A abordagem qualitativa permite interpretar a sequência de atividades, as responsabilidades dos setores e os riscos associados à operação manual. O caráter descritivo é utilizado para registrar o cenário As-Is e o cenário To-Be sem afirmar que a implementação já foi concluída.

3.2 Levantamento de Requisitos

O levantamento foi estruturado a partir da análise do processo descrito para a PavPlas e do documento “Requisitos de Usuário”. Foram identificadas as jornadas do administrador, do operador financeiro, do backoffice, da logística e do cliente final. Em seguida, as necessidades

foram transformadas em requisitos funcionais, administrativos, não funcionais, histórias de usuário e critérios de aceitação.

A técnica de documentação utiliza identificadores únicos, prioridade e status de validação. O status “A validar” é mantido quando a regra depende de confirmação com a empresa, como limite monetário para dupla aprovação, prazo de reserva de estoque, provedor de pagamento e parâmetros de frete. Essa decisão evita apresentar como definido aquilo que ainda é uma premissa do projeto.

3.3 Metodologia de Desenvolvimento

Para o desenvolvimento futuro, recomenda-se uma abordagem iterativa inspirada em Scrum ou em um fluxo Kanban. O backlog deve ser organizado por valor e risco, começando pelos componentes que estruturam o ciclo de venda: catálogo, carrinho, estoque, checkout, pagamentos e atualização de pedidos. Em paralelo, os requisitos de segurança e auditoria devem ser implementados desde o início, e não como uma etapa posterior.

Cada ciclo deve conter planejamento, implementação, testes, demonstração e revisão dos critérios de aceitação. A equipe deve manter documentação de API, decisões de arquitetura, matriz de permissões e evidências de teste. A conclusão de uma etapa somente deve ocorrer quando os critérios correspondentes forem validados pelos representantes do negócio.

4 ANÁLISE DO PROBLEMA

A PavPlas atua no setor de peças para máquinas industriais e, no processo analisado, depende de interações humanas para concluir as vendas. O site funciona como vitrine, o cliente é direcionado ao WhatsApp, a equipe consulta estoque e frete em recursos separados e o pagamento é confirmado mediante conferência manual. Depois da confirmação, o pedido é encaminhado para separação, faturamento e expedição.

4.1 Processo Atual (As-Is)

O fluxo atual pode ser resumido da seguinte forma: o cliente consulta o catálogo; entra em contato com a empresa; o atendimento verifica disponibilidade e preço; o frete é calculado; os dados de pagamento são enviados; o cliente realiza PIX ou transferência; o financeiro verifica o comprovante; o estoque é separado; a nota fiscal é emitida; e a transportadora é acionada. Como

as informações percorrem diferentes canais, o mesmo pedido pode ser reprocessado por áreas distintas.

4.2 Revisão do Processo As-Is

A revisão do processo As-Is evidencia que a venda não é conduzida por um fluxo sistêmico único, mas por uma sequência de atividades distribuídas entre site, WhatsApp, planilhas, sistemas internos e comunicação entre setores. O site cumpre a função de apresentação dos produtos, enquanto o atendimento comercial assume a responsabilidade de transformar o interesse do cliente em pedido. A partir desse ponto, as informações precisam ser confirmadas manualmente antes de chegar ao financeiro e à logística.

Etapas	Atividade observada	Responsável principal	Ponto de atenção
1. Consulta	Cliente consulta produtos e entra em contato pelo canal de atendimento.	Cliente e atendimento comercial.	A jornada começa no catálogo, mas a compra não é concluída no próprio site.
2. Cotação	Equipe verifica preço, disponibilidade e condições de frete.	Atendimento comercial.	Consultas manuais podem gerar demora e divergência de informação.
3. Pagamento	Empresa envia dados bancários e cliente realiza PIX ou transferência.	Cliente e financeiro.	A confirmação depende da análise de comprovante e da comunicação entre canais.
4. Liberação	Financeiro informa que o pedido pode seguir para operação.	Operador financeiro.	Não há atualização automática e padronizada do status do pedido.
5. Separação	Estoque separa o produto após receber a informação da venda.	Estoque e logística.	A ausência de uma fila integrada pode gerar retrabalho ou separação indevida.
6. Faturamento	Nota fiscal é emitida e vinculada ao pedido.	Setor fiscal/ERP.	A redigitação aumenta o risco de erros cadastrais e fiscais.
7. Expedição	Transportadora é acionada e o pedido é enviado.	Logística.	O cliente possui pouca visibilidade do andamento e do rastreamento.

A revisão também mostra que os principais controles dependem da intervenção humana: conferência de estoque, validação do pagamento, atualização do pedido, comunicação com o setor seguinte e retorno ao cliente. O processo funciona quando as pessoas conseguem sincronizar as

informações, mas se torna vulnerável a atrasos, mensagens incompletas, duplicidade de registros e perda de histórico.

Com base nessa análise, a melhoria prioritária não é apenas disponibilizar novas formas de pagamento. É necessário criar uma fonte única de informação para o pedido, relacionar cada transação a um identificador, registrar as mudanças de status e automatizar as notificações entre os setores. Dessa forma, o gateway passa a apoiar a revisão do processo inteiro, e não somente a etapa de cobrança.

4.3 Problemas Identificados

A análise do fluxo evidencia quatro grupos de problemas. O primeiro é a dependência humana e de horário comercial, pois a venda precisa de atendimento e conferência financeira. O segundo é a vulnerabilidade na conciliação, uma vez que imagens ou mensagens podem ser interpretadas de forma incorreta ou fraudulenta. O terceiro é a existência de silos de informação, que aumenta a redigitação e o risco de divergência. O quarto é a fricção na experiência do cliente, que precisa trocar de plataforma para concluir a compra.

Esses problemas não representam apenas uma dificuldade operacional. Eles afetam a confiabilidade do estoque, a previsibilidade do faturamento, a velocidade de expedição e a capacidade de gerar indicadores gerenciais. A solução deve, portanto, integrar o fluxo sem eliminar controles e responsabilidades.

4.4 Processo Proposto (To-Be)

No cenário proposto, o cliente escolhe os produtos em uma plataforma de e-commerce, adiciona os itens ao carrinho e informa o endereço de entrega. O sistema valida o estoque, consulta o serviço de frete e apresenta o resumo da compra. No checkout, o gateway cria a cobrança de acordo com a modalidade escolhida: PIX, boleto bancário ou cartão de crédito.

Após o retorno do gateway, o sistema registra o evento e atualiza o pedido. Quando o pagamento é confirmado, o estoque é baixado, os dados são enviados ao ERP, a NF-e é solicitada, a ordem de separação é gerada e o financeiro recebe os dados de conciliação. O cliente acompanha o status na própria área de pedidos. Quando a transação está pendente, recusada ou cancelada, o pedido não deve avançar para a expedição.

4.5 Requisitos Funcionais

4.5.1 Tabela de Requisitos Funcionais

ID	Requisito funcional	Justificativa	Prioridade	Status
RF-01	Permitir cadastro e autenticação de clientes.	Identificação no checkout.	Alta	A validar
RF-02	Exibir catálogo de produtos com informações atualizadas.	Catálogo virtual.	Alta	A validar
RF-03	Adicionar, alterar e remover produtos do carrinho.	Carrinho de compras.	Alta	A validar
RF-04	Consultar e exibir a disponibilidade dos produtos em estoque.	Validação do inventário.	Alta	A validar
RF-05	Impedir a finalização sem estoque suficiente.	Evitar vendas indisponíveis.	Alta	A validar
RF-06	Coletar e validar endereço de entrega.	Etapa de entrega.	Alta	A validar
RF-07	Calcular automaticamente o valor do frete.	Integração logística.	Alta	A validar
RF-08	Apresentar previsão de entrega.	Retorno logístico.	Média	A validar
RF-09	Permitir seleção da modalidade de entrega.	Definição do frete.	Média	A validar
RF-10	Apresentar resumo do pedido antes da confirmação.	Checkout integrado.	Alta	A validar
RF-11	Permitir pagamento por PIX.	Modalidade do cenário To-Be.	Alta	A validar
RF-12	Gerar QR Code e código PIX Cópia e Cola.	Automação do PIX.	Alta	A validar
RF-13	Permitir pagamento por boleto bancário.	Modalidade do cenário To-Be.	Alta	A validar
RF-14	Gerar boleto e disponibilizá-lo ao cliente.	Automação do boleto.	Alta	A validar
RF-15	Permitir pagamento por cartão de crédito.	Modalidade do cenário To-Be.	Alta	A validar
RF-16	Apresentar opções de parcelamento configuradas.	Parcelamento parametrizado.	Média	A validar
RF-17	Enviar a transação ao gateway.	Integração de pagamento.	Alta	A validar
RF-18	Receber e registrar o resultado retornado pelo gateway.	Aprovação ou recusa.	Alta	A validar
RF-19	Informar ao cliente se o pagamento foi aprovado, recusado ou está pendente.	Retorno sistêmico.	Alta	A validar
RF-20	Atualizar automaticamente o status do pedido após a confirmação.	Estado "Pago".	Alta	A validar
RF-21	Enviar confirmação de pagamento e pedido por e-mail.	Notificação ao cliente.	Média	A validar
RF-22	Efetuar baixa do produto após confirmação do pagamento.	Integração de estoque.	Alta	A validar
RF-23	Enviar dados do pedido e cliente ao ERP.	Integração de faturamento.	Alta	A validar
RF-24	Solicitar emissão automática da NF-e.	Emissão fiscal.	Alta	A validar
RF-25	Disponibilizar ou enviar a NF-e ao cliente.	Entrega do documento fiscal.	Alta	A validar
RF-26	Gerar ordem de separação para a logística.	Automação do backoffice.	Alta	A validar
RF-27	Gerar etiqueta de postagem ou transporte.	Preparação da expedição.	Média	A validar
RF-28	Atualizar o pedido conforme o andamento da expedição.	Integração logística.	Média	A validar
RF-29	Permitir acompanhamento do status pelo cliente.	Rastreabilidade.	Média	A validar

ID	Requisito funcional	Justificativa	Prioridade	Status
RF-30	Registrar a entrada financeira da venda confirmada.	Controle financeiro.	Alta	A validar
RF-31	Realizar conciliação automática dos pagamentos.	Eliminar conferência manual.	Alta	A validar
RF-32	Disponibilizar informações para relatórios financeiros.	Controle gerencial.	Média	A validar
RF-33	Manter histórico de pedidos do cliente.	Consulta na área do cliente.	Média	A validar
RF-34	Permitir gerenciamento autorizado de produtos, preços e estoque.	Manutenção do e-commerce.	Alta	A validar
RF-35	Permitir consulta administrativa de pedidos e status.	Controle integrado.	Alta	A validar

4.5.2 Regras de Negócio Associadas

1. a baixa definitiva do estoque ocorrerá somente após a confirmação do pagamento;
2. pedidos com pagamento pendente poderão reservar estoque por prazo definido pela PavPlas;
3. o pedido somente seguirá para separação após a confirmação do pagamento;
4. as opções de parcelamento serão parametrizadas pela empresa;
5. o valor e o prazo do frete dependerão do CEP, do peso, das dimensões e da tabela da transportadora;
6. pagamentos recusados não gerarão ordem de separação nem solicitação de NF-e;
7. operações críticas deverão possuir identificador de usuário, horário, motivo e resultado.

4.6 Perfis de Usuário e Jornadas

O documento de requisitos identifica cinco perfis. A distinção entre eles é necessária para aplicar o princípio do menor privilégio, no qual cada pessoa acessa somente os módulos necessários à sua atividade. O perfil não é apenas uma categoria visual: ele deve estar associado a permissões explícitas e a registros de auditoria.

Perfil	Necessidade principal	Limite de acesso
Administrador do sistema	Configurar acessos, visualizar logs de auditoria e gerenciar chaves de integração do gateway.	Acesso administrativo amplo, sujeito à segregação e à auditoria.
Operador financeiro / gateway	Acompanhar transações, realizar conciliações e efetuar estornos ou reembolsos com segurança.	Acesso financeiro; estornos de alto valor exigem dupla confirmação.

Perfil	Necessidade principal	Limite de acesso
Atendente de backoffice / suporte	Consultar pedidos, verificar comprovantes e atender clientes.	Não visualiza dados sensíveis completos e não executa estornos.
Operador de logística / expedição	Acessar pedidos pagos, emitir etiquetas e atualizar rastreios.	Visualiza somente pedidos com pagamento confirmado e não acessa dados de cartão.
Cliente final	Escolher forma de pagamento, receber confirmação e consultar histórico.	Acessa somente os próprios dados e pedidos.

4.7 Histórias de Usuário e Critérios de Aceitação

As histórias de usuário complementam os requisitos ao registrar o objetivo de cada perfil e o valor esperado. Os critérios de aceitação tornam a regra testável e reduzem interpretações divergentes entre negócio, análise e desenvolvimento.

4.7.1 RU01 – Autenticação Segura com Controle por Papéis (RBAC)

Como administrador do sistema, quero vincular cada colaborador a um perfil de acesso específico, para que cada funcionário acesse apenas os módulos necessários ao seu trabalho. Cada perfil deve possuir permissões explícitas de leitura, criação, edição ou exclusão por módulo. Usuários não autorizados devem receber mensagem de erro e bloqueio visual ao tentar acessar rotas restritas. A sessão deve expirar automaticamente após 30 minutos de inatividade.

4.7.2 RU02 – Gestão de Estornos e Operações Sensíveis do Gateway

Como operador financeiro, quero solicitar e aprovar estornos diretamente no painel, para que devoluções sejam processadas com rastreabilidade. Estornos acima do valor definido pela PavPlas exigirão dupla confirmação ou aprovação de um perfil administrador. O sistema deverá registrar data, hora, motivo e identificador do operador. Perfis de backoffice e logística não poderão visualizar ou acionar o botão de estorno.

4.7.3 RU03 – Visibilidade Restrita de Pedidos para Logística

Como operador de logística, quero visualizar somente os pedidos cujo pagamento já foi compensado no gateway, para que a expedição não envie itens não pagos. Pedidos pendentes, recusados ou cancelados não devem aparecer na fila de separação. O operador não terá acesso a dados completos de cartão ou detalhes bancários do cliente.

4.7.4 RU04 – Mascaramento de Dados Sensíveis e Conformidade

Como atendente de backoffice, quero consultar detalhes do pedido sem visualizar os dados completos do cartão de crédito, para que a empresa mantenha a conformidade com padrões

de segurança. Apenas os últimos quatro dígitos e a bandeira poderão ser exibidos quando necessários ao atendimento. Dados completos de cartão nunca deverão ser exibidos em tela, armazenados em texto puro ou registrados em logs.

4.7.5 RU05 – Logs de Auditoria de Acesso e Alteração

Como administrador, quero consultar um relatório de auditoria, para rastrear quem realizou alterações de permissões ou operações críticas no gateway. O registro deverá ser imutável e conter timestamp, usuário, IP, ação realizada e status de sucesso ou falha. Os logs de auditoria somente poderão ser visualizados pelo perfil administrador.

4.8 Requisitos Administrativos (Backoffice)

ID	Requisito	Módulo	Descrição ou regra de uso	Prioridade
RAD-01	Controle de acesso baseado em papéis (RBAC).	Segurança	Diferenciar Administrador, Financeiro, Fiscal, Estoque, Logística e Atendimento.	Alta
RAD-02	Autenticação segura e auditoria.	Segurança	Registrar alterações de preço, cancelamentos, estornos e permissões.	Alta
RAD-03	Cadastro e edição de produtos e categorias.	Catálogo	Gerenciar fotos, descrições, preços, dimensões, peso e visibilidade.	Alta
RAD-04	Ajuste e controle de saldo de estoque.	Inventário	Registrar entrada, perda, avaria e inventário periódico.	Alta
RAD-05	Alerta de estoque mínimo.	Alertas	Notificar operadores sobre itens em baixa quantidade.	Média
RAD-06	Gestão centralizada de pedidos.	Pedidos	Filtrar por Pendente, Pago, Em separação, Faturado, Enviado, Concluído e Cancelado.	Alta
RAD-07	Alteração manual justificada de status.	Pedidos	Permitir intervenções somente a operadores autorizados, com justificativa.	Alta
RAD-08	Parametrização do gateway.	Financeiro	Configurar credenciais, parcelas, descontos e prazos de expiração.	Alta
RAD-09	Painel de conciliação financeira.	Relatórios	Comparar valores brutos, taxas, valores líquidos e status de liquidação.	Alta
RAD-10	Reenvio de notificações e links.	Suporte	Reenviar PIX, boleto, comprovante ou comunicação ao cliente.	Média
RAD-11	Sincronização com fiscal e ERP.	Integração	Monitorar fila de faturamento e status de emissão de NF-e.	Alta
RAD-12	Relatórios gerenciais e dashboards.	Gestão/BI	Exibir vendas, produtos, ticket médio, abandono e faturamento por modalidade.	Média
RAD-13	Gerenciamento de tabelas de frete.	Logística	Parametrizar transportadoras, prazos, taxas fixas e regras regionais.	Média

4.9 Requisitos Não Funcionais

Os requisitos não funcionais qualificam o comportamento esperado da solução e devem ser validados durante os testes. Como os parâmetros finais dependem da infraestrutura e dos provedores escolhidos, alguns valores permanecem como metas a confirmar.

ID	Categoria	Requisito	Prioridade
RNF-01	Segurança	Toda comunicação entre cliente, aplicação e integrações deve utilizar canal protegido por TLS.	Alta
RNF-02	Segurança	Credenciais e chaves de API não devem ser armazenadas no código-fonte nem expostas em logs.	Alta
RNF-03	Privacidade	Dados de cartão devem ser tokenizados ou encaminhados ao provedor, sem armazenamento completo em texto puro.	Alta
RNF-04	Acesso	A sessão deve expirar após 30 minutos de inatividade e permitir revogação de acesso.	Alta
RNF-05	Auditoria	Ações críticas devem gerar registro imutável com usuário, IP, timestamp, ação e resultado.	Alta
RNF-06	Desempenho	A interface deve responder em tempo adequado para as operações comuns, com metas a serem definidas após medição da infraestrutura.	Média
RNF-07	Disponibilidade	Falhas de integração devem ser identificadas, registradas e encaminhadas para reprocessamento controlado.	Alta
RNF-08	Usabilidade	As mensagens de erro devem orientar o usuário sem revelar informações sensíveis ou detalhes internos.	Média
RNF-09	Manutenibilidade	A API, as integrações e as regras de status devem possuir documentação atualizada.	Média
RNF-10	Escalabilidade	A camada de integração deve permitir adição ou substituição de provedores sem reescrever o núcleo do pedido.	Média

5 MODELAGEM E ARQUITETURA

A arquitetura proposta separa a experiência do cliente, as regras de negócio e as integrações externas. Essa separação reduz o acoplamento entre o e-commerce e o provedor de pagamento, facilita testes e permite que eventos sejam tratados de forma rastreável. A solução é apresentada como modelo arquitetural para orientar uma implementação posterior.

5.1 Arquitetura da Solução

A camada de apresentação contém o catálogo, o carrinho, o checkout, a área do cliente e os painéis administrativos. A camada de aplicação coordena pedidos, pagamentos, estoque, pedidos de expedição, notificações e auditoria. A camada de integração comunica-se com gateway,

serviço de frete, ERP, emissão fiscal e transportadora. A camada de persistência armazena dados operacionais e o histórico de eventos.

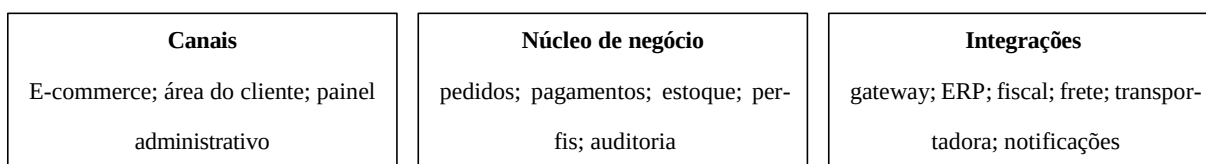


Figura 1: Arquitetura lógica proposta para o gateway de pagamento.

O princípio de funcionamento é o seguinte: a aplicação cria o pedido e solicita a cobrança; o gateway retorna a identificação da transação; a aplicação acompanha a resposta síncrona ou recebe um webhook; o evento é validado e persistido; o pedido muda de estado de acordo com a regra; e os módulos dependentes são acionados. Eventos duplicados devem ser reconhecidos pelo identificador da transação e tratados de forma idempotente.

5.2 Casos de Uso

Os principais casos de uso são: cadastrar e autenticar cliente; consultar catálogo; montar carrinho; calcular frete; iniciar checkout; escolher meio de pagamento; consultar resultado; acompanhar pedido; administrar produtos; consultar pedidos; conciliar pagamentos; solicitar ou aprovar estorno; configurar integrações; gerenciar perfis; e consultar auditoria. O escopo inicial deve priorizar os casos diretamente ligados à venda e à segurança.

5.3 Modelo de Dados

O modelo de dados deve relacionar `Cliente`, `Pedido`, `ItemPedido`, `Produto`, `Estoque`, `Pagamento`, `EventoPagamento`, `Entrega`, `NotaFiscal`, `Usuario`, `Perfil`, `Permissao` e `LogAuditoria`. Um pedido possui um ou mais itens e pode possuir uma ou mais tentativas de pagamento, desde que o sistema controle qual tentativa é válida e impeça liquidação duplicada.

A entidade `Pagamento` deve armazenar identificador interno, provedor, identificador externo, modalidade, valor, status, datas de criação e atualização e informações minimizadas de apresentação. A entidade `EventoPagamento` deve preservar o payload necessário à investigação, com proteção de acesso e retenção definida. A entidade `LogAuditoria` deve registrar ação, usuário, IP, timestamp, status e motivo, sem incluir dados completos de cartão ou segredos de integração.

5.4 Fluxo de Pagamento

1. o cliente confirma o carrinho e o endereço;
2. o sistema valida preço, disponibilidade e frete;
3. o cliente escolhe PIX, boleto ou cartão;
4. a aplicação cria a solicitação de pagamento com chave de idempotência;
5. o gateway devolve o resultado inicial e o identificador da transação;
6. a aplicação registra o evento e informa ao cliente se o pagamento está aprovado, recusado ou pendente;
7. uma confirmação posterior, quando necessária, atualiza o pedido e aciona estoque, ERP, NF-e, logística e financeiro;
8. falhas ou divergências são encaminhadas para conciliação e reprocessamento controlado.

6 SEGURANÇA

A segurança é requisito transversal da solução. O gateway não deve ser tratado como um simples formulário de pagamento, pois ele coordena informações pessoais, financeiras, operacionais e fiscais. Os controles precisam ser incorporados à arquitetura, ao código, à infraestrutura e aos procedimentos administrativos.

6.1 Autenticação e Autorização

A autenticação deve confirmar a identidade do usuário e, quando aplicável, utilizar segundo fator de autenticação para administradores e operadores financeiros. A autorização deve ser baseada em papéis e permissões granulares por módulo, contemplando leitura, criação, edição e exclusão. A aplicação deve validar as permissões no servidor, pois o bloqueio visual no navegador não constitui controle suficiente.

A expiração após 30 minutos de inatividade reduz o risco de uso indevido de sessões abandonadas. Também devem existir revogação de sessões, política de recuperação de conta, proteção contra tentativas repetidas e armazenamento seguro de senhas por algoritmo apropriado. Chaves de integração devem possuir rotação e escopo limitado.

6.2 Proteção de Dados

O atendimento e a logística devem visualizar somente as informações necessárias à própria função. Para cartão de crédito, a interface pode mostrar a bandeira e os quatro últimos dígitos, mas nunca o número completo, código de segurança ou dados equivalentes. Logs, mensagens de erro, exportações e relatórios devem ser submetidos à mesma regra de minimização.

O sistema deve separar dados de identificação, dados de pagamento e dados operacionais, restringindo acessos e definindo retenção. O projeto deve documentar finalidade, base legal aplicável, responsáveis pelo tratamento, procedimentos de atendimento ao titular e resposta a incidentes, conforme avaliação jurídica e institucional da PavPlas.

6.3 Criptografia

A comunicação externa deve utilizar HTTPS com TLS atualizado, certificados válidos e validação de cadeia. Dados sensíveis em repouso devem ser protegidos com controles de acesso e, quando indicado, criptografia. A aplicação não deve registrar segredos em texto puro e deve impedir que tokens de acesso sejam enviados para a interface ou armazenados em arquivos de configuração públicos.

O uso de tokenização reduz a exposição do sistema a dados completos de cartão. A escolha do mecanismo depende do provedor e dos requisitos de conformidade, devendo ser validada antes da implementação. A segurança também inclui assinatura ou validação de webhooks, controle de origem, prevenção de replay e registro do resultado de cada validação.

6.4 Controle de Acesso

A matriz abaixo traduz os perfis do documento de requisitos em permissões de alto nível. O detalhamento CRUD deverá ser definido por módulo e aprovado pela instituição.

Perfil	Pedidos	Pagamentos	Estoque	Estornos	Auditoria
Administrador	Gerenciar	Gerenciar	Gerenciar	Aprovar	Consultar
Financeiro/Gateway	Consultar	Operar	Consultar	Solicitar/Aprovar conforme limite	Não
Backoffice/Suporte	Consultar	Consultar status	Não	Não	Não
Logística/Expedição	Somente pagos	Não	Atualizar expedição	Não	Não
Cliente final	Próprios	Próprio checkout	Não	Não	Não

6.5 LGPD e Auditoria

O tratamento de dados deve observar os princípios da LGPD e ser limitado às finalidades do pedido, pagamento, atendimento, faturamento e expedição. O acesso a logs de auditoria é exclusivo do administrador, e os logs devem ser protegidos contra alteração indevida. Ao mesmo tempo, a proteção não pode impedir a investigação: os registros devem manter os elementos necessários para saber quem fez o quê, quando, de onde e com qual resultado.

As operações críticas de estorno exigem dupla confirmação acima do limite definido. O sistema deve guardar a justificativa, o usuário solicitante, o usuário aprovador, o valor, o identificador da transação, o horário e o resultado. Essa segregação reduz o risco de que uma única conta execute e aprove a mesma operação sensível.

7 CONCLUSÃO

7.1 Considerações Finais

O trabalho analisou o processo de vendas e pagamentos da PavPlas e estruturou uma proposta de gateway integrado ao comércio eletrônico, estoque, financeiro, fiscal, logística e ERP. O cenário atual apresenta dependência de WhatsApp, conferência manual, fragmentação de informações e dificuldade de rastreabilidade. O cenário futuro organiza a jornada do cliente e define condições para que um pedido pago avance para as etapas operacionais.

A incorporação do documento de requisitos ampliou a monografia ao incluir perfis de usuário, jornadas, histórias de usuário, critérios de aceitação, controle de acesso por papéis, mascaramento de dados, auditoria e operações sensíveis. Esses elementos tornam a proposta mais verificável e aproximam a modelagem das necessidades dos setores que utilizarão a solução.

O objetivo geral foi atendido no escopo de análise e modelagem. A monografia não afirma que o gateway foi colocado em produção; ela oferece uma especificação estruturada para desenvolvimento, validação e futura implantação. Para concluir a implementação, será necessário validar premissas com a PavPlas, escolher os provedores, detalhar contratos de API, construir o software e executar testes com dados controlados.

7.2 Limitações

As principais limitações são a ausência de implantação produtiva, a falta de métricas históricas detalhadas, a necessidade de confirmação dos limites para estornos e reservas de estoque e a indefinição do provedor de pagamentos, do ERP e da transportadora. Também não foram apresentados neste documento códigos executáveis ou evidências de testes de carga, segurança e disponibilidade.

Outra limitação é que parâmetros como tempo de resposta, volume de transações, política de retenção e metas de disponibilidade dependem da infraestrutura e dos contratos da empresa. Por isso, os requisitos que dependem de medição permanecem como metas a validar, evitando transformar hipóteses em resultados.

7.3 Trabalhos Futuros

Como continuidade, recomenda-se implementar um protótipo funcional, selecionar um ou mais provedores e testar pagamentos por PIX, boleto e cartão em ambiente de homologação. Também devem ser desenvolvidos webhooks idempotentes, conciliação automática, retentativas controladas, antifraude, observabilidade, alertas e mecanismos de contingência.

É igualmente importante realizar testes de segurança com base em uma lista de verificação reconhecida, revisar a matriz de permissões com os responsáveis de cada setor, formalizar o ciclo de vida dos dados pessoais e executar testes de aceitação com usuários reais. Após a implantação, indicadores de conversão, tempo de confirmação, taxa de falhas, abandono de carrinho, tempo de expedição e divergência de estoque poderão medir os benefícios do projeto.

REFERÊNCIAS

- [1] ABPMP. **BPM CBOK: guia para o gerenciamento de processos de negócio: corpo comum de conhecimento**. ABPMP, 2013.
- [2] HAMMER, Michael. **Reengenharia: a revolução no gerenciamento**. Rio de Janeiro: Campus, 1994.
- [3] STRIPE. **Benefícios de gateway de pagamentos para empresas**. Disponível em: <https://stripe.com/br/resources/more/five-key-benefits-of-payment-gateways-for-businesses>. Acesso em: 20 ago. 2026.
- [4] FIELDING, Roy T.; et al. **HTTP Semantics**. RFC 9110. Internet Engineering Task Force, 2022. Disponível em: <https://www.rfc-editor.org/info/rfc9110>. Acesso em: 20 ago. 2026.
- [5] BRASIL. **Lei nº 13.709, de 14 de agosto de 2018: Lei Geral de Proteção de Dados Pessoais**. Brasília, DF: Presidência da República, 2018. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm. Acesso em: 20 ago. 2026.
- [6] OWASP. **Application Security Verification Standard**. Disponível em: <https://owasp.org/www-project-application-security-verification-standard/>. Acesso em: 20 ago. 2026.
- [7] SOMMERVILLE, Ian. **Engenharia de software**. 10. ed. São Paulo: Pearson, 2019.
- [8] BRASIL. Autoridade Nacional de Proteção de Dados. **Lei Geral de Proteção de Dados Pessoais: guia orientativo**. Disponível em: <https://www.gov.br/anpd/pt-br>. Acesso em: 20 ago. 2026.